Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

College name: Nandha Arts and Science College

College Code: bru4j

Team ID : SWTID-2026-9998

Team Size : 5

Team Leader : YUGESH.K

Email: yugeshk1452006@gmail.com

Team member : THARANITHARAN D

Email: tharanit643@gmail.com

Team member : AASHIK SHARIFF S

Email: aashikshariff06@gmail.com

Team member : VIMAL R

Email: vimalravi505@gmail.com

Team member : BARATH B

Email: barathcsa@gmail.com

Project details Title:

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, this project initiates a fundamental shift in our security architecture. We will be decommissioning our legacy VPN infrastructure, which relies on an outdated castleand-moat model that grants excessive network access and is vulnerable to lateral threat movement. To replace it, we are adopting a cloud-native, Zero Trust approach powered by Zscaler. This new architecture is built on the principle of "never trust, always verify," ensuring that users are connected to applications, not to the network. By making applications invisible to the internet and establishing direct, secure user-to-app connections, we will drastically reduce our attack surface. This modern solution eliminates the risk of lateral movement, as threats can no longer traverse a flat network. Furthermore, it provides a superior, high-performance experience for our hybrid workforce, decoupling security from data center backhauling. The transition to Zscaler will not only bolster our security posture but also enhance agility and reduce the operational overhead associated with managing legacy hardware. This initiative is a critical step in future-proofing our organization against sophisticated cyber threats.

Abstract:

This project details the strategic migration from a legacy Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution provided by Zscaler. The primary driver for this initiative is the fundamental inadequacy of traditional VPNs in the modern threat landscape. Legacy architectures operate on a "connect first, verify later" model, granting users broad access to the corporate network and, consequently, creating a significant risk of lateral movement by malicious actors. This expansive attack surface, combined with the operational overhead of managing physical appliances and the poor user experience associated with hair-pinned traffic, renders the existing model both insecure and inefficient for today's hybrid workforce. The proposed solution leverages the Zscaler Zero Trust Exchange, a global, cloud native platform that shifts connectivity from a network-centric to an identity and applicationcentric model. By making corporate applications invisible to the internet and establishing direct, secure connections between verified users and specific applications, the new architecture eliminates the concept of network-based privileges. This approach ensures that users connect to the applications they need, not the underlying network, thereby completely neutralizing the threat of lateral movement. Furthermore, it improves performance by steering traffic directly to Zscaler’s edge nodes, optimizing the user experience regardless of their location. The expected outcomes of this modernization project are multifaceted. We anticipate a drastic reduction in the organization's attack surface and the complete elimination of lateral movement risks. This will be coupled with a simplified, scalable security posture managed from a unified cloud console, reducing operational costs and complexity. Ultimately, this transition will not only fortify our cyber defenses against sophisticated threats but also enable a secure, high performance, and agile work environment, future-proofing the organization's security architecture.

Use Case Scenarios

Scenario 1: Third-Party Vendor Access to Finance Application

An external auditor requires temporary access to the organization's finance application for auditing purposes. Instead of providing full VPN access, the Zero Trust architecture grants the vendor access only to the specific finance application through applicationlevel access control.

Output:

- User identity verified through Identity Provider
- Time-limited access granted
- Connection restricted only to the finance application
- No access to internal network resources

Scenario 2: Research Assistant Access to High-Performance Computing Cluster

A research assistant needs SSH access to a computing cluster to run data analysis scripts. Using Zero Trust Network Access, the user is authenticated and allowed to connect only to the HPC server.

Output:

- User identity verified
- Protocol-specific access (SSH only)
- Secure micro-tunnel created to the target server
- Other network segments remain inaccessible

Scenario 3: Administrative Staff Access to Internal File Server

An administrative staff member working remotely needs to access internal files stored on the organization’s file server. Instead of connecting through a traditional VPN, the system verifies the user's identity and device posture before granting applicationspecific access.

Output:

- Identity verification completed
- Device posture check passed
- Access granted only to the file server
- Data Loss Prevention policies applied

Scenario 4: IT Administrator Secure Access to Server Management Interfaces

An IT administrator requires remote access to manage internal servers through Remote Desktop Protocol (RDP). Using the Zero Trust model, the administrator is authenticated and granted access only to the required server management interface.

Output:

- Administrator identity verified
- Privileged access control enforced
- Secure encrypted micro-tunnel established
- Session monitoring and logging enabled

Scenario 5: Visiting Professor Access to Library Resources

A visiting professor from another institution needs temporary access to digital library archives hosted within the organization's internal network. The Zero Trust system provides limited and time-bound access to the specific library application.

Output:

- User identity verified
- Time-limited access granted
- Connection restricted to library application
- No access to other internal systems

Stage-1:

Title: - Replace and modernize legacy VPN architectures with a cloudnative Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Web Application Vulnerability Testing

Overview

Stage-1 focuses on identifying common web application security vulnerabilities using a practice website. The purpose of this stage is to understand how attackers may exploit weaknesses in web applications and how these vulnerabilities can impact system security. For this project, the practice website used for vulnerability analysis is:

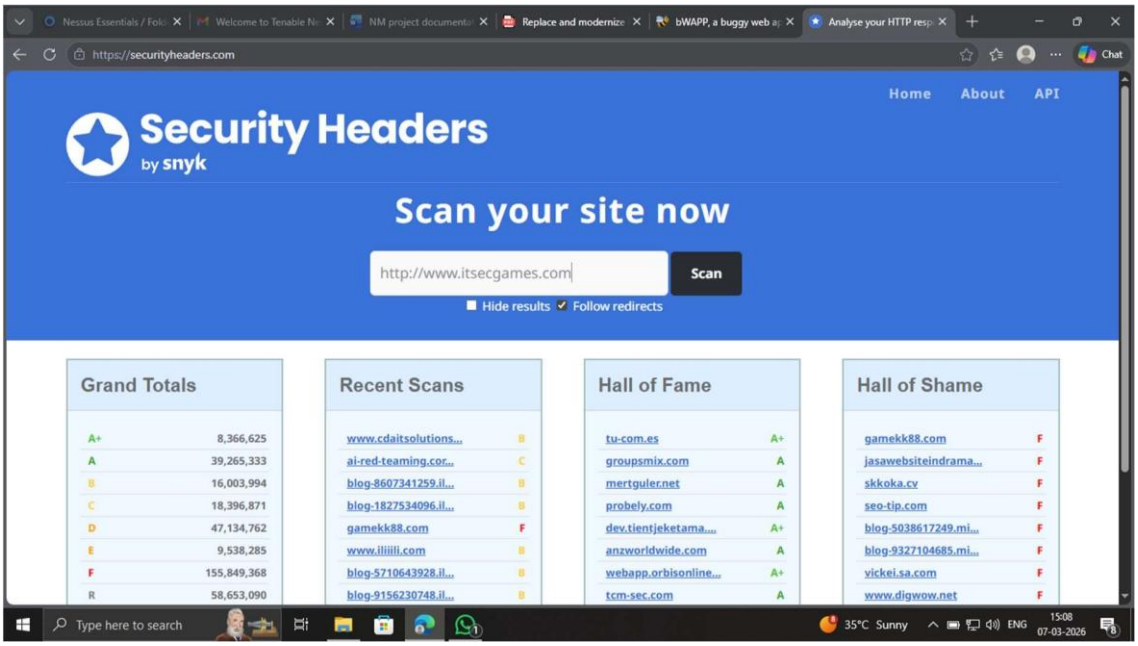
http://www.itsecgames.com

The vulnerabilities identified in this stage are based on the OWASP Top 10, which is a globally recognized list of the most critical web application security risks.

Vulnerability Details

1. Improper Sanitization of File Paths

CWE: CWE-284 – Improper Access Control



Description:

Improper Access Control This occurs when an application does not properly validate or restrict access to sensitive files. Attackers may manipulate file paths to view restricted data on the server.

Business Impact:

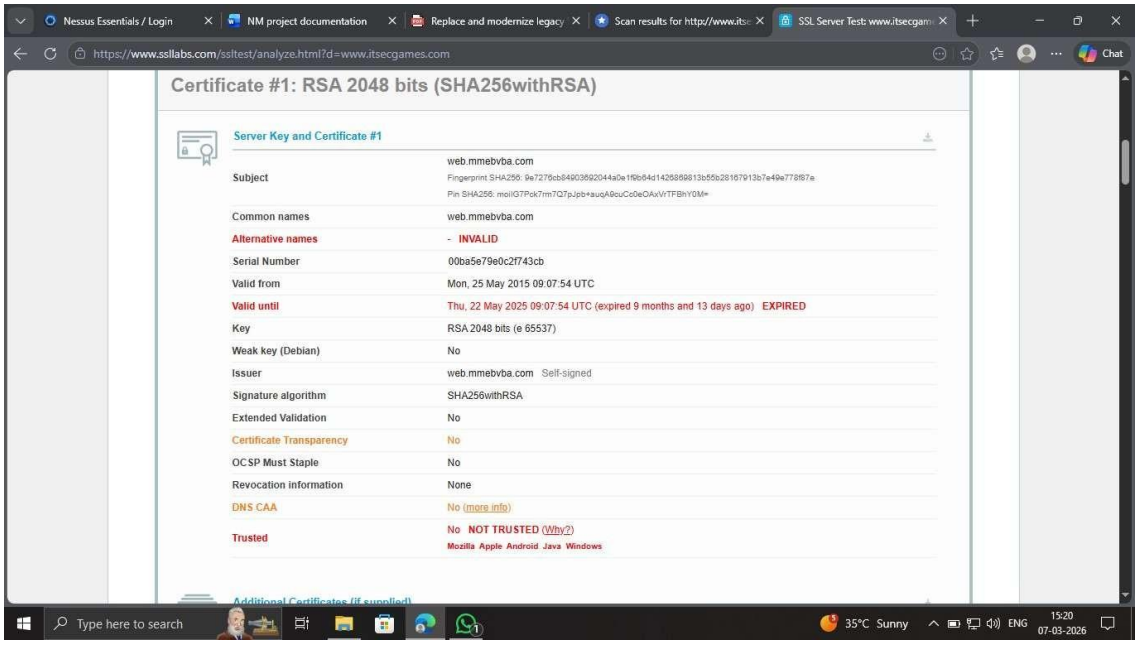
Attackers may gain unauthorized access to sensitive configuration data or private information stored on the server.

Recommendation:

- Implement strict access control policies
- restrict file system permissions
- regularly audit file access.

2. Invalid Certificate

CWE: CWE-395 – Improper Certificate Validation



Description:

Improper Certificate Validation An invalid or improperly configured SSL certificate may allow attackers to impersonate trusted systems and intercept communications between users and the server.

Business Impact:

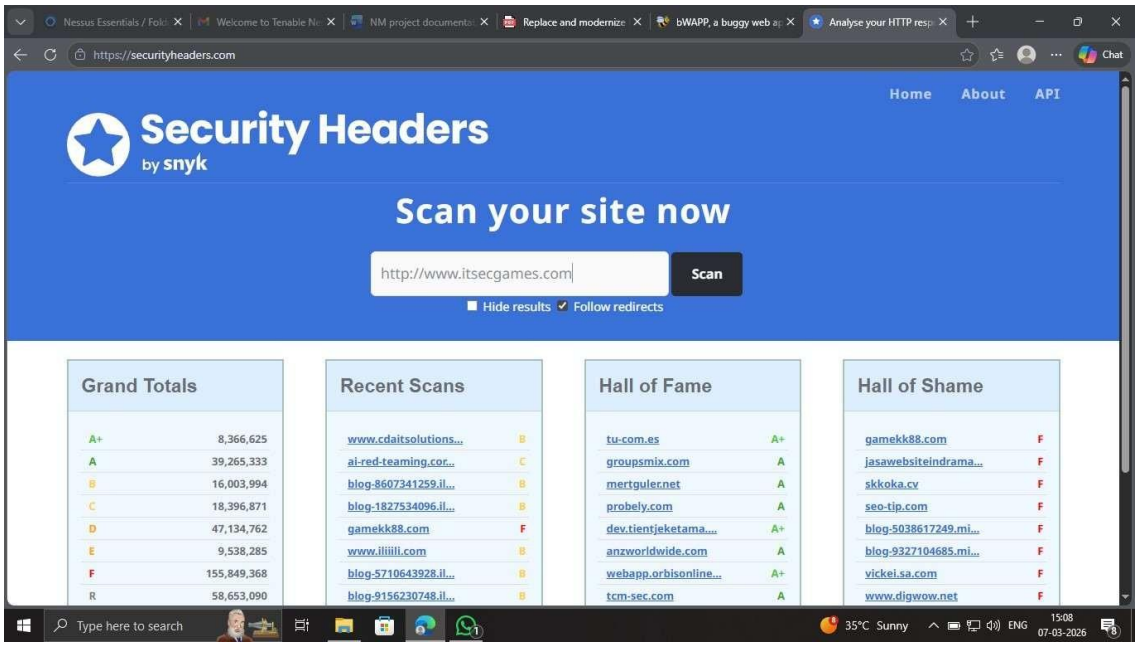
This leads to Man-in-the-Middle (MitM) attacks, data interception, and unauthorized access to sensitive data.

Recommendation:

Use trusted certificate authorities, validate certificate chains, and implement certificate pinning.

3. Missing X-Frame-Options Header

CWE: CWE-1021 – Improper Restriction of Rendered UI Layers



Description:

Improper Restriction of Rendered UI Layers The absence of this header allows a web page to be embedded within an iframe on another website. This can lead to clickjacking attacks where users unknowingly interact with malicious content.

Business Impact:

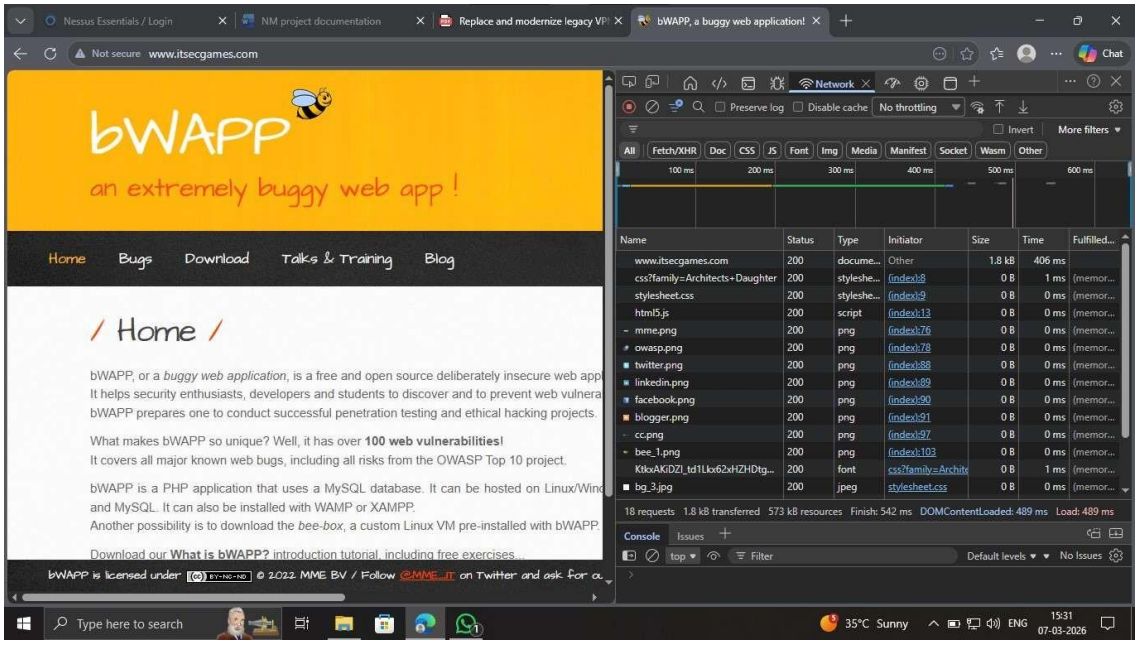
Unauthorized user actions, user interface manipulation, and potential data theft.

Recommendation:

Implement the X-Frame-Options header and use a Content Security Policy (CSP) to restrict iframe embedding.

4. X-Content-Type Options Header Missing

CWE: CWE-918 – Server-Side Request Forgery



Description:

Server-Side Request Forgery (Mismatched) When this header is missing, browsers may attempt to guess the content type of files. This allows attackers to manipulate how the browser interprets and executes data.

Business Impact:

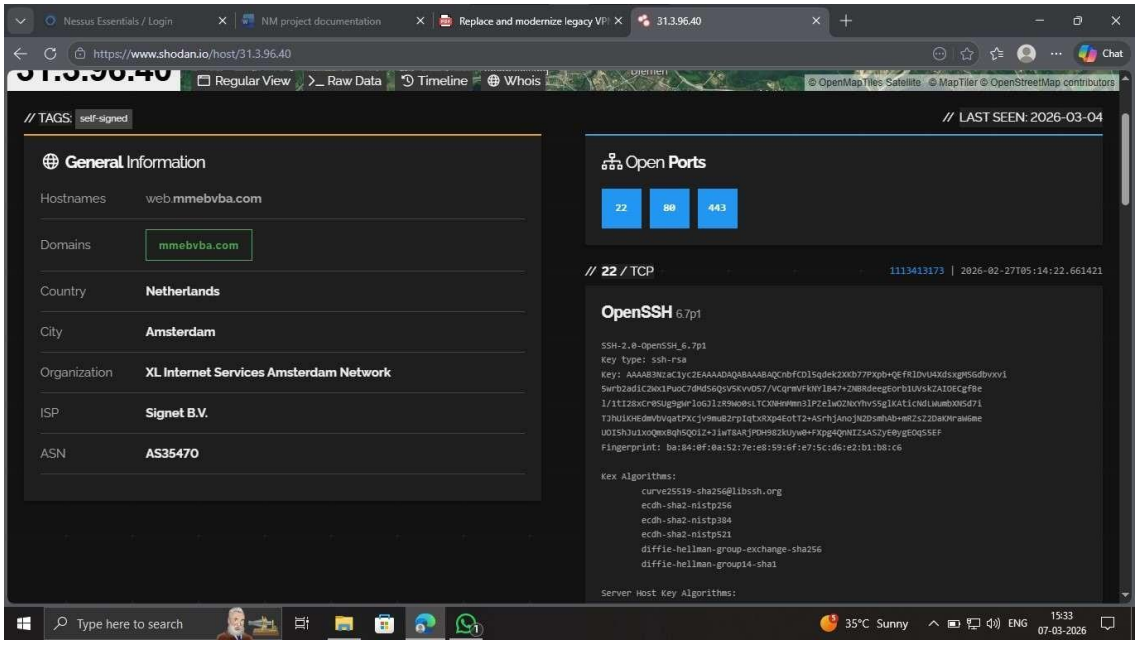
Data exposure, security bypass, and potential cross-site scripting (XSS) attacks.

Recommendation:

Add the following security header in the server configuration: X-Content-Type-Options: nosniff.

5. Drupal Ajax API Shows JSONP Not Disabled

CWE: CWE-937 / CWE-1035 – Using Components with Known Vulnerabilities



Description:

Using Components with Known Vulnerabilities Some Drupal API configurations allow JSONP requests by default. This may expose the application to vulnerabilities when outdated components or insecure configurations are used.

Business Impact:

Exploitation of outdated components, remote code execution, and unauthorized system access.

Recommendation:

Update Drupal components regularly and disable any unused APIs.

6. Drupal API Vulnerability (Improper Input Validation)

CWE: CWE-20 – Improper Input Validation

Description:

Improper Input Validation Improper validation of user input may allow attackers to inject malicious data into the application, potentially leading to SQL injection or command injection attacks.

Business Impact:

Database compromise, data theft, and full system manipulation.

Recommendation: Validate and sanitize all user inputs, use parameterized queries, and follow secure coding practices.

7. Improper API Filtration (Cross-Site Scripting)

CWE: CWE-79 – Cross-Site Scripting (XSS)

Description:

Cross-Site Scripting (XSS) Cross-Site Scripting occurs when a web application allows user input to be executed as a script in another user's browser.

Business Impact:

Session hijacking, credential theft, and website defacement.

Recommendation:

Encode user input properly and implement a strong Content Security Policy (CSP).

8. Denial of Service (DoS)

CWE: CWE-400 – Uncontrolled Resource Consumption

Description:

Uncontrolled Resource Consumption A Denial-of-Service attack attempts to overwhelm the server with excessive requests, causing the system to become unavailable to legitimate users.

Business Impact:

Service interruption, system downtime, and loss of business operations.

Recommendation:

Implement rate limiting, use Web Application Firewalls (WAF), and monitor network traffic patterns.

9. TLS Version 1.0 Protocol Detection

CWE: CWE-327 – Use of Broken or Risky Cryptographic Algorithm

Description:

Use of Broken or Risky Cryptographic Algorithm TLS 1.0 is an outdated encryption protocol that contains known vulnerabilities and is no longer considered secure for modern web traffic.

Business Impact:

Weak encryption, risk of data interception, and non-compliance with modern security standards.

Recommendation:

Disable TLS 1.0 and enable TLS 1.2 or TLS 1.3.

10. web.config File Information Disclosure

CWE: CWE-497 – Exposure of Sensitive Information

Description:

Exposure of Sensitive Information If the web.config file is accessible publicly, attackers may obtain sensitive configuration information, including database credentials.

Business Impact:

Total system compromise, data leakage, and unauthorized system access.

Recommendation:

Restrict access to configuration files, encrypt sensitive data, and implement strict access controls.

Conclusion:

The vulnerability assessment of the practice website identified several common web application security weaknesses. These range from improper access control and outdated cryptographic protocols to cross-site scripting and configuration exposure.

Addressing these vulnerabilities is essential to protect sensitive data and prevent unauthorized access. Ensuring the overall security of web applications requires a proactive approach to patching and configuration management.

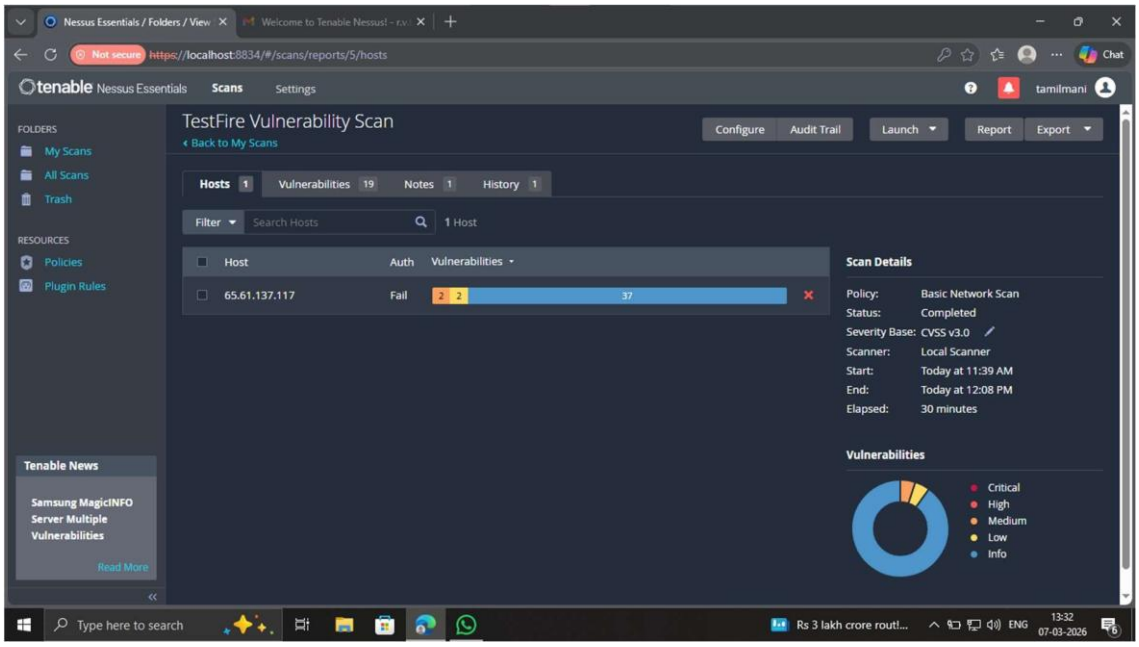
Stage-2

Title: - Replace and modernize legacy VPN architectures with a cloudnative Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Vulnerability Scanning Using Nessus – Overview

In this stage, a vulnerability assessment was performed using Nessus, a widely used network security scanning tool developed by Tenable. Nessus is designed to identify security weaknesses in systems, networks, and web applications by sending various probes to the target host and analyzing its responses.

The scanner works through a plugin-based architecture, where each plugin is responsible for detecting a specific vulnerability such as outdated encryption protocols, insecure configurations, or exposed services. During the scanning process, Nessus first performs host discovery and service detection to determine the operating system and running services on the target system. After identifying these services, the scanner executes multiple vulnerability checks using its database of plugins.

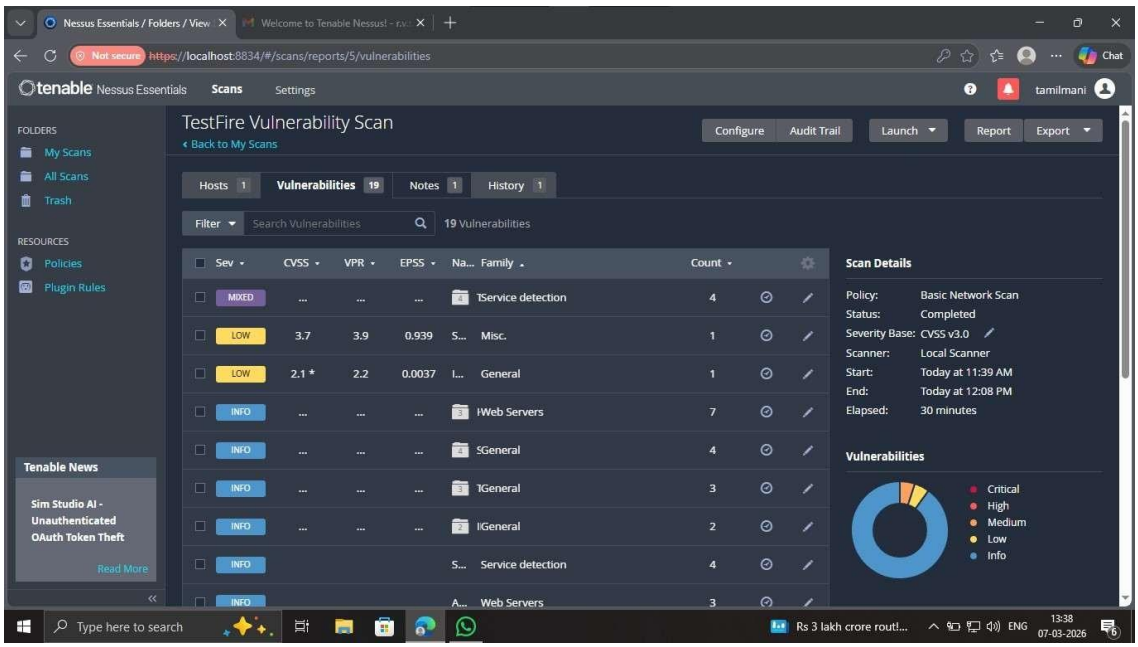


For this project, the target system selected for the vulnerability assessment was:

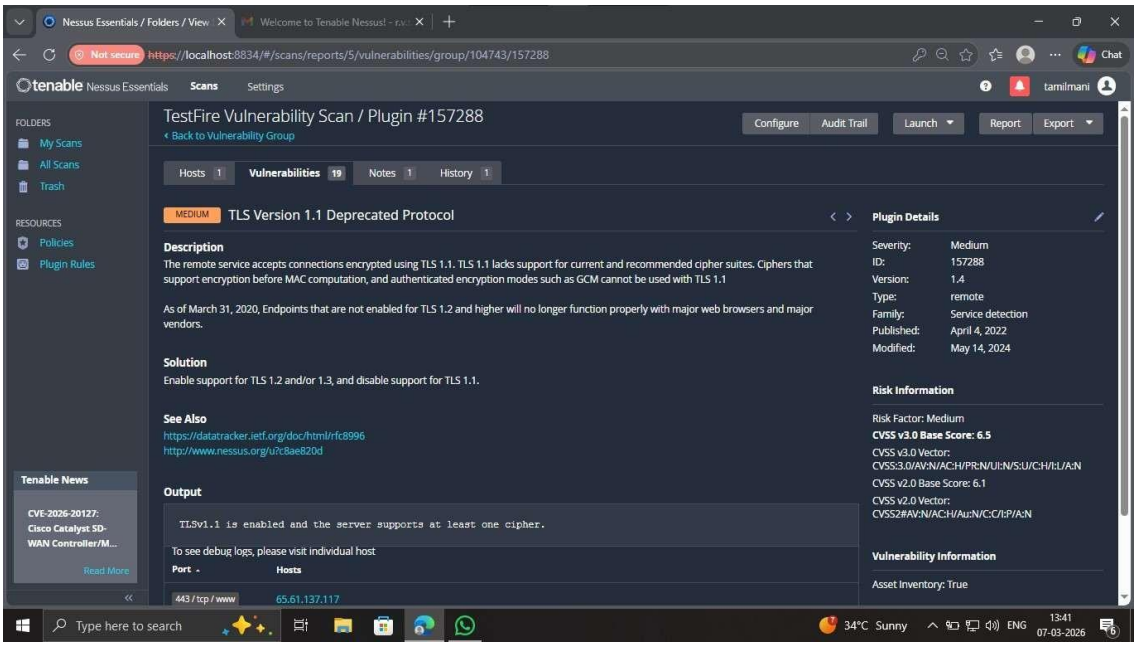
Target Website : http://testfire.net

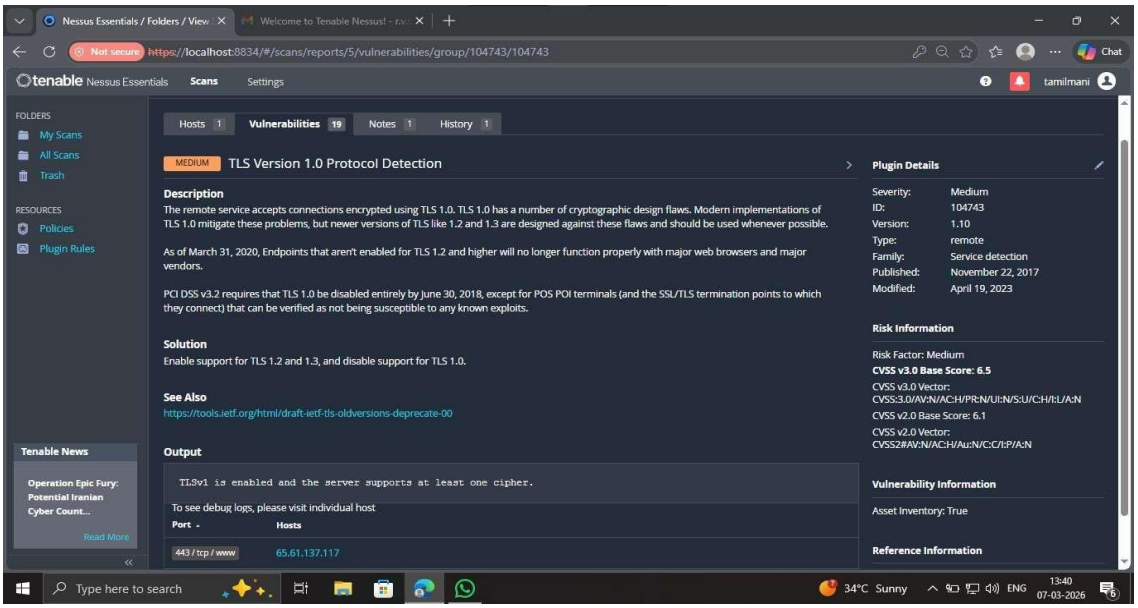
Target IP : 65.61.137.117

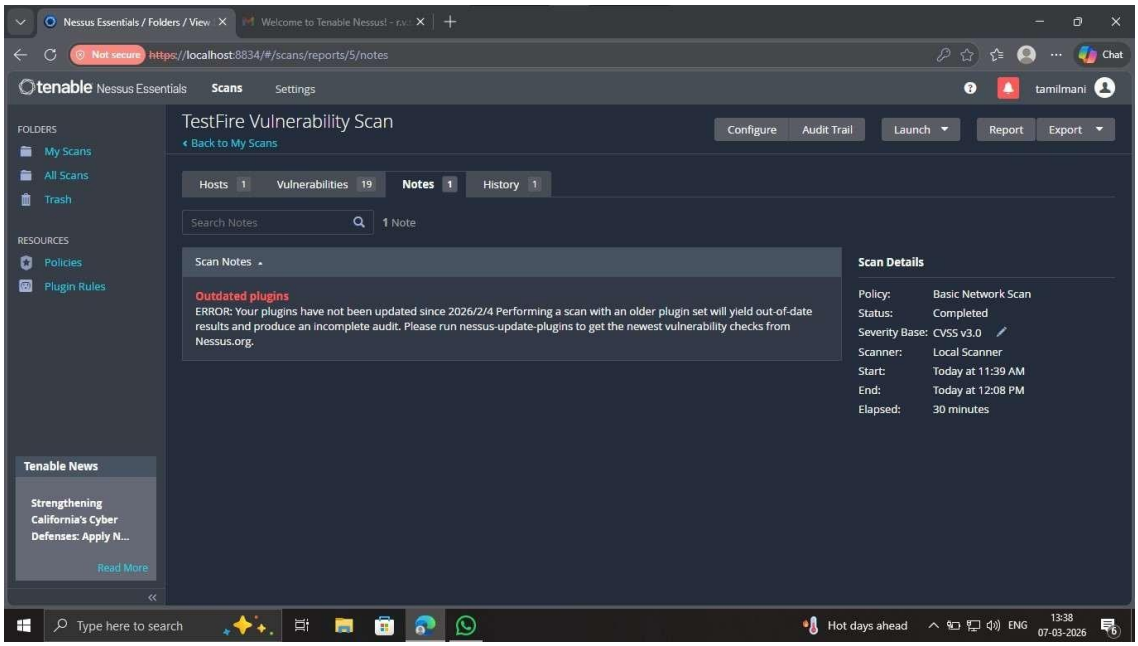
The Nessus scan was configured using a **Basic Network Scan policy,** which performs a comprehensive assessment of the host by checking common network ports and identifying potential security vulnerabilities. After the scan was completed, Nessus generated a detailed report containing vulnerability findings categorized by severity levels such as **Medium, Low, and Informational.**



The results from the scan provided insight into several security issues present in the target system, including outdated TLS encryption protocols and server configuration information. These findings help security professionals understand potential weaknesses in the system and recommend appropriate remediation measures to improve overall security.


Nessus Essentials / Folders / View
Welcome to Tenable Nessus! - r.v.
Not secure https://localhost:8834/#/scans/reports/5/vulnerabilities/group/104743/157288
Chat
tenable Nessus Essentials
Scans
Settings
tamilmani
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
CVE-2026-20127: Cisco Catalyst SD-WAN Controller/M...
Read More
TestFire Vulnerability Scan / Plugin #157288
Back to Vulnerability Group
Configure
Audit Trail
Launch
Report
Export
Hosts 1
Vulnerabilities 19
Notes 1
History 1
MEDIUM
TLS Version 1.1 Deprecated Protocol
Description
The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1
As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.
Solution
Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.
See Also
https://datatracker.ietf.org/doc/html/rfc8996
http://www.nessus.org/u?c8ae820d
Output
TLSv1.1 is enabled and the server supports at least one cipher.
To see debug logs, please visit individual host
Port
Hosts
443 / tcp / www
65.61.137.117
Plugin Details
Severity: Medium
ID: 157288
Version: 1.4
Type: remote
Family: Service detection
Published: April 4, 2022
Modified: May 14, 2024
Risk Information
Risk Factor: Medium
CVSS v3.0 Base Score: 6.5
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N
CVSS v2.0 Base Score: 6.1
CVSS v2.0 Vector: CVSS2#AV:N/AC:H/Au:N/C:C/I:P/A:N
Vulnerability Information
Asset Inventory: True
Type here to search
34°C Sunny
ENG
13:41
07-03-2026


Nessus Essentials / Folders / View
Welcome to Tenable Nessus! - r.v.
Not secure https://localhost:8834/#/scans/reports/5/vulnerabilities/group/104743/104743
Chat
tenable Nessus Essentials
Scans
Settings
tamilmani
FOLDERS
My Scans
All Scans
Trash
RESOURCES
Policies
Plugin Rules
Tenable News
Operation Epic Fury: Potential Iranian Cyber Count...
Read More
Hosts 1
Vulnerabilities 19
Notes 1
History 1
MEDIUM
TLS Version 1.0 Protocol Detection
Description
The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.
As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.
PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.
Solution
Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.
See Also
https://tools.ietf.org/html/draft-ietf-tls-oldversions-deprecate-00
Output
TLSv1 is enabled and the server supports at least one cipher.
To see debug logs, please visit individual host
Port
Hosts
443 / tcp / www
65.61.137.117
Plugin Details
Severity: Medium
ID: 104743
Version: 1.10
Type: remote
Family: Service detection
Published: November 22, 2017
Modified: April 19, 2023
Risk Information
Risk Factor: Medium
CVSS v3.0 Base Score: 6.5
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N
CVSS v2.0 Base Score: 6.1
CVSS v2.0 Vector: CVSS2#AV:N/AC:H/Au:N/C:C/I:P/A:N
Vulnerability Information
Asset Inventory: True
Reference Information
Type here to search
34°C Sunny
ENG
13:40
07-03-2026



List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1.	Nessus Scan Information	INFO	19506
2.	OS Fingerprints Detected	INFO	209654
3.	TCP/IP Timestamps Supported	INFO	25220
4.	Common Platform Enumeration (CPE)	INFO	45590
5.	Nessus SYN scanner	INFO	11219
6.	Device Type	INFO	54615
7.	OS Identification	INFO	11936

REPORT: -

1.Nessus Scan Information

- **Severity:** INFO
- **Plugin ID:** 19506
- **Description:** This plugin displays summary information about the scan itself, including the version of the Nessus engine, the scanner IP, the scan duration, and whether the scan was credentialed (authenticated) or unauthenticated.
- **Solution:** No action is required. This is for record-keeping and audit purposes.
- **Business Impact:** High-level visibility. It ensures that the scan was performed correctly and within the expected timeframe, providing a "heartbeat" for compliance documentation.

2. OS Fingerprints Detected

- **Severity:** INFO
- **Plugin ID:** 11936 / 102001 (Consolidated)
- **Description:** This plugin lists the potential operating systems running on the target host based on the fingerprints gathered during the scan.
- **Solution:** Verify that the detected OS matches your internal asset inventory.
- **Business Impact:** Understanding the "landscape" of your network. If an unauthorized or end-of-life (EOL) OS is detected, it could represent an unmanaged risk to the organization.

3. TCP/IP Timestamps Supported

- **Severity:** INFO
- **Plugin ID:** 25220
- **Description:** The remote host responds to TCP timestamp requests. This feature allows the scanner to estimate the uptime of the target and synchronize timing for packet transmission.
- **Solution:** While generally harmless, if your security policy requires hiding system uptime, you can disable TCP timestamps in the OS network stack.
- **Business Impact:** Low. It provides minor reconnaissance data to a potential attacker (like how long a server has been up), but does not directly allow for system compromise.

4. Common Platform Enumeration (CPE)

- **Severity**: INFO
- **Plugin ID:** 45590
- **Description:** This plugin generates a standardized "CPE" string (e.g., cpe:/o:linux:kernel:5.4) for the detected hardware, operating systems, and applications.
- **Solution:** No action required. This is a classification tool.
- **Business Impact:** Asset Management. Standardized CPE strings allow your security team to quickly cross-reference assets against the National Vulnerability Database (NVD) for future threats.

5. Nessus SYN Scanner

- **Severity:** INFO
- **Plugin ID:** 11219
- **Description:** This confirms that the Nessus scanner performed a "half-open" SYN scan to identify open ports. It lists which ports were found to be open, closed, or filtered.
- **Solution:** Review the list of open ports. Close any ports or services that are not strictly necessary for business operations.

6. Device Type

- **Severity**: INFO
- **Plugin ID:** 54615
- **Description:** Based on the gathered data, Nessus classifies the device type (e.g., General Purpose, Router, Printer, Embedded Device).
- **Solution:** Verify that the device is correctly identified and belongs in its designated network segment (e.g., printers should be on an isolated VLAN).
- **Business Impact:** Network Architecture Validation. Helps identify "shadow IT" or rogue devices (like a personal router) that may have been plugged into the corporate network.

7. OS Identification

- **Severity:** INFO
- **Plugin ID:** 11936
- **Description:** This plugin attempts to determine the remote operating system by examining responses from the target's network stack (TCP/IP fingerprinting) and, if available, by checking specific services like SNMP, HTTP, or SMB. Unlike "OS Fingerprints Detected," this plugin provides the final, most confident assessment of the OS name and version.
- **Solution:** No direct technical action is required. However, administrators should verify that the identified OS is a supported version (not "End of Life") and that it matches the organization's official asset inventory.
- **Business Impact:** * Scan Accuracy: Knowing the exact OS prevents "False Positives" (e.g., the scanner won't check for Windows vulnerabilities on a Linux machine). o **Lifecycle Management**: It helps leadership identify aging systems that no longer receive security patches, which is a primary driver for data breaches.
    - **Compliance:** Many frameworks (like PCI-DSS or HIPAA) require an accurate, upto-date inventory of all operating systems on the network.

Stage-3

Title: - Replace and modernize legacy VPN architectures with a cloudnative Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview

Traditional network security models rely heavily on Virtual Private Networks (VPNs) to allow remote users to access internal organizational resources. These legacy VPN architectures operate on a perimeter-based security model, often referred to as the castleand-moat approach. In this model, once a user successfully authenticates to the VPN, they are granted broad access to the internal network.

However, this architecture is no longer suitable in modern environments where organizations support remote work, cloud services, and distributed applications. The traditional VPN model introduces several security risks, including increased attack surface and the possibility of **lateral movement**, where attackers move across systems inside the network after gaining initial access.

Replace and modernize legacy VP…

To address these issues, organizations are shifting toward a **Zero Trust Network Access (ZTNA)** architecture using solutions such as **Zscaler Private Access**, which is part of the **Zscaler Zero Trust Exchange** platform.

Legacy VPN Architecture

Legacy VPN solutions establish an encrypted tunnel between remote users and the organization’s internal network using VPN concentrators or gateway devices. Once authenticated, users are placed directly on the internal network and assigned an internal IP address.

This approach has several limitations:

1. **Over-permissioned access** – Users gain access to the entire network instead of only the applications they need.
2. **Expanded attack surface** – VPN gateways must expose ports to the public internet.
3. **Risk of lateral movement** – Attackers can move between internal systems if one device is compromised.
4. **Poor user experience** – Traffic is often routed through centralized data centers, causing latency.
5. **Operational overhead** – Organizations must maintain VPN hardware, apply patches, and manage capacity.

These limitations make legacy VPN systems vulnerable to modern cyber threats.

The Problem: Attack Surface and Lateral Movement

One of the biggest risks associated with traditional VPN architectures is the expanded attack surface. VPN gateways expose services to the internet, making them targets for attackers who perform port scanning, credential-stuffing attacks, or exploit vulnerabilities.

Another major issue is lateral movement. Once attackers gain access to the network through stolen credentials or compromised devices, they can scan the internal network and access other systems such as file servers, databases, and application servers.

This increases the likelihood of large-scale security breaches and data exfiltration.

Zero Trust Security Model

To overcome these challenges, organizations are adopting the Zero Trust security model, which follows the principle: Never Trust, Always Verify

In a Zero Trust architecture:

- No user or device is automatically trusted.
- Every access request must be authenticated and authorized.
- Users are granted access only to specific applications rather than the entire network.

Zero Trust eliminates implicit trust within the network and significantly reduces security risks.

Zscaler Private Access (ZPA)

Zscaler Private Access (ZPA) is a cloud-native security solution that implements the Zero Trust model. Instead of connecting users to the network, ZPA connects users directly to the applications they need.

Key features of ZPA include:

1. Application-Level Access

Users connect directly to specific applications instead of the entire network.

2. Identity-Based Access Control

Access decisions are based on user identity, device posture, and security policies.

3. Micro-Segmentation

Each application is isolated from others, preventing attackers from moving laterally.

4. Invisible Applications

Internal applications are not exposed to the internet, reducing the attack surface.

5. Secure Micro-Tunnels

ZPA establishes encrypted micro-tunnels between users and applications, ensuring secure communication.

Benefits of the Zscaler Zero Trust Architecture

The adoption of Zscaler's Zero Trust architecture provides several advantages:

Reduced Attack Surface

Applications are hidden from the public internet, preventing direct attacks.

Prevention of Lateral Movement

Users can access only the specific applications they are authorized to use.

Improved Performance

Traffic is routed through Zscaler's global cloud infrastructure rather than centralized data centers.

Simplified IT Operations

Organizations no longer need to maintain complex VPN hardware.

Enhanced Security Posture

Continuous authentication and authorization reduce the risk of unauthorized access.

Conclusion

The transition from legacy VPN architecture to a cloud-native Zero Trust solution using Zscaler significantly improves the organization's security and operational efficiency. By eliminating network-level access and enforcing application-level access controls, the Zero Trust model reduces attack surface and prevents lateral movement within the network.Implementing Zscaler Private Access enables organizations to provide secure, scalable, and high-performance remote access while protecting critical applications from modern cyber threats.

Additional Sections (Template Alignment)

SOC (Security Operations Center)

A Security Operations Center (SOC) is a centralized unit that monitors, detects, and responds to cybersecurity threats within an organization. The SOC team continuously analyzes security alerts, logs, and network traffic to identify suspicious activities and respond to incidents.

SOC Cycle

The SOC cycle generally includes monitoring, detection, investigation, response, and recovery. Security analysts monitor alerts, analyze suspicious events, respond to incidents, and improve defenses to prevent future attacks.

SIEM (Security Information and Event Management)

SIEM is a cybersecurity technology used to collect, analyze, and correlate security logs from multiple devices such as servers, firewalls, and applications. It helps detect potential threats and generate alerts for security teams.

SIEM Cycle

The SIEM cycle includes log collection, normalization, correlation of events, threat detection, alert generation, and incident response.

MISP

MISP (Malware Information Sharing Platform) is an open-source threat intelligence platform that allows organizations to share information about malware, indicators of compromise, and cyber threats.

College Network Information

A college network typically includes administrative systems, student portals, library systems, laboratory computers, and internet gateways. Proper monitoring and security tools are required to protect these systems from cyber threats.

Deploying SOC in College

A SOC can be deployed in the college environment to monitor network activity, detect security incidents, and respond quickly. This would involve implementing SIEM tools, log monitoring systems, and dedicated security analysts.

Threat Intelligence

Threat intelligence refers to collecting and analyzing information about cyber threats. This information helps organizations understand attacker behavior and prepare defensive strategies.

Incident Response

Incident response is the process of identifying, analyzing, containing, and recovering from cybersecurity incidents. A proper incident response plan helps organizations minimize damage and restore systems quickly.

QRadar

IBM QRadar is a SIEM platform used for threat detection, log analysis, and security monitoring. It collects security data from multiple sources and provides dashboards for analyzing potential threats.

Final Conclusion

Stage■1 helped identify common web application vulnerabilities such as missing security headers and weak configurations. Stage■2 used Nessus to perform automated vulnerability scanning and identify encryption and configuration weaknesses. Stage■3 explained how Zero Trust architecture using Zscaler reduces attack surface and prevents lateral movement.

Future Scope

1. Enhancing web application testing with automated vulnerability scanning tools.
2. Continuous vulnerability monitoring using advanced scanning platforms.
3. Implementing a full SOC environment with SIEM monitoring tools.

Topics Explored

1. Web Application Security
2. Vulnerability Scanning
3. Zero Trust Architecture
4. SOC and SIEM
5. Threat Intelligence

Tools Explored

1. Nessus Vulnerability Scanner
2. Security Headers Scanner
3. Browser Developer Tools
4. Zscaler Platform
5. SIEM / QRadar